

GOVERNANCE AND RISK MODEL **v2026**

A practical approach to cybersecurity governance, risk, and compliance

GRM
2026

> TABLE OF CONTENTS

Introduction.....	3
The CRF Governance and Risk Model in the CCRF Ecosystem	4
Execution Maturity Across the GRC Roadmap	5
The Business Purpose for Cybersecurity Governance	6
The Business Purposes for Cybersecurity Risk Management.....	7
An Overview of the Governance, Risk, and Compliance (GRC) Roadmap	11
Step One: Initiate.....	13
Step Two: Inventory	15
Step Three: Select.....	17
Step Four: Educate	22
Step Five: Implement	23
Stage Six: Validate	27
Stage Seven: Communicate	29
Progressing Towards Cybersecurity Program Maturity.....	30
Conclusion	31
About the Cybersecurity Risk Foundation.....	32

➤ INTRODUCTION

The 2026 edition of the Cybersecurity Risk Foundation – Governance and Risk Model (CRF-GRM) represents a significant evolution in how organizations approach cybersecurity governance. This updated model introduces a refined GRC Roadmap that provides a structured, step-by-step framework for integrating cybersecurity into organizational strategy. With this roadmap, we aim to bridge the gap between high-level governance objectives and actionable implementation, ensuring that organizations have both the strategic vision and the practical tools to execute effective cybersecurity programs. This release is not just an iteration—it’s a transformation that aligns cybersecurity governance with business goals more deliberately and measurably.

One of the most impactful updates in this edition is our focus on clarity and specificity in implementation guidance. Building on previous frameworks, the CRF-GRM now includes more detailed, actionable instructions for organizations at varying cybersecurity maturity levels. This includes a deeper alignment with industry standards, enhanced risk management methodologies, and improved strategies for selecting and validating cybersecurity safeguards. Rather than prescribing broad best practices, this model provides a clear roadmap for execution, enabling leadership teams, security professionals, and operational stakeholders to confidently implement and maintain robust cybersecurity programs.

A key advantage of the CRF-GRM is its seamless integration with other CRF frameworks, enabling organizations to build a cohesive, practical cybersecurity strategy. When used together, these resources create a unified approach to cybersecurity governance, risk management, and continuous improvement—helping organizations move beyond theory and into measurable, actionable cybersecurity success. This integration ensures that cybersecurity is not managed in silos but is instead embedded into every layer of an organization’s operations, enabling both security resilience and business agility.

The 2026 CRF-GRM is designed to be a living framework adaptable to emerging risks, technological advancements, and evolving regulatory expectations. By leveraging this enhanced model, organizations can strengthen their governance structures, improve risk communication, and implement precise safeguards—ultimately fostering a resilient cybersecurity posture that supports long-term business success. Whether an organization is just beginning its cybersecurity journey or refining an established program, the CRF-GRM offers a structured yet flexible approach to achieving cybersecurity excellence.

➤ THE CRF GOVERNANCE AND RISK MODEL IN THE CRF ECOSYSTEM

The Cybersecurity Risk Foundation (CRF) Governance and Risk Model (GRM) defines the orchestration layer of an organization's cybersecurity program. It establishes which governance and risk management activities must occur and when, across the cybersecurity lifecycle. The GRM is intentionally focused on sequence, purpose, and decision points rather than execution detail.

Within the broader CRF ecosystem, the GRM works in coordination with complementary CRF frameworks that each serve a distinct role. The CRF Governance & Risk Management Maturity Model (CRF-GRMM) provides a maturity lens for evaluating how well the activities defined in the GRM are executed, from informal to optimized. The GRMM does not redefine the roadmap steps; it measures execution quality and governance consistency across those steps.

The CRF Audit Framework (CRF-AF) defines how cybersecurity safeguards are independently validated through governed assurance activities. Audit authority, evidence standards, and assurance conclusions are owned by the CRF-AF. The CRF Business Intelligence Model (CRF-BIM) defines how continuous evidence, metrics, and reporting are generated to support governance, oversight, and audit activities. The BIM improves visibility and evidence quality but does not replace independent validation.

Together, these frameworks form a cohesive system:

- **The GRM defines governance intent and sequencing.**
- **The GRMM measures the maturity of execution.**
- **The BIM generates continuous evidence and insight.**
- **The AF delivers independent validation and assurance.**

By clearly separating orchestration, maturity, evidence, and assurance, the CRF ecosystem enables organizations to build cybersecurity programs that are structured, measurable, and defensible—without collapsing governance, execution, and validation into a single activity.

➤ THE CRF GOVERNANCE AND RISK MODEL IN THE CRF ECOSYSTEM

Execution maturity across the seven steps of the GRC Roadmap is evaluated using the CRF Governance & Risk Management Maturity Model (CRF-GRMM). The GRMM provides a consistent lens for assessing how well each roadmap step is executed—from informal and ad hoc practices to optimized, repeatable, and well-governed execution.

The GRM defines which governance and risk management activities must occur and when. The GRMM evaluates how maturely those activities are carried out across each step. Maturity does not change the roadmap's sequence or intent; it reflects the quality, consistency, integration, and scalability of execution.

Unless otherwise stated, each step of the GRC Roadmap should be interpreted through this maturity lens. Organizations may be at different maturity levels across different steps, and progression does not require uniform advancement across the entire roadmap.

➤ THE BUSINESS PURPOSE FOR CYBERSECURITY GOVERNANCE

The fundamental aim of a cybersecurity program is to strengthen an organization's technological infrastructure against potential threats and vulnerabilities. By doing so, cybersecurity ensures that the technology systems integral to business operations function optimally and reliably. In essence, a robust cybersecurity framework directly supports the technology systems, enabling them to effectively facilitate the organization's broader goals.

Said another way,

“Cybersecurity programs ultimately exist to support an organization's technology systems, so those systems, in turn, can enable an organization to achieve its purpose.”

The objective of a cybersecurity program extends beyond merely ensuring cybersecurity. It isn't an end in itself but a means to a larger organizational end. While the technical measures and protocols are pivotal, their primary function is not just to secure digital assets but to underpin the entire business infrastructure. In this context, cybersecurity emerges as a foundational pillar, designed not for its own sake but to bolster, sustain, and facilitate the broader goals and operations of the business as a whole. It exists to serve and fortify the organization's overarching mission and objectives.

Cybersecurity governance, when viewed through the lens of program management, encompasses a structured framework that aligns security strategies and operations with organizational objectives, ensuring cybersecurity measures are effectively managed and continuously optimized to meet the evolving needs and goals of the organization. This governance framework defines clear roles, responsibilities, processes, and performance metrics to ensure that cybersecurity initiatives are coordinated, standardized, and effectively managed across the organization. It's akin to program management in that it requires coordinated effort across projects, resources, and stakeholders to achieve a higher-level strategic objective, ensuring cybersecurity risks are adequately mitigated while enabling the organization to achieve its business objectives securely.

➤ THE BUSINESS PURPOSES FOR CYBERSECURITY RISK MANAGEMENT

In modern cybersecurity risk management strategies, there is great confusion about the purpose of risk management. Without a clear purpose, the methodology or steps of cybersecurity risk management remain unclear. Organizations struggle to define terms such as risk, threat, and vulnerability. Without clear definitions, an organization cannot build a straightforward process. Too many risk models focus on the academic aspects of risk rather than the practicality of understanding and mitigating risk. For the purpose of this discussion, the assumption will be that an organization is implementing a cybersecurity risk management program to ensure its technology platforms continue to support the organization's overall business goals.

To accomplish this, we believe there are three main activities an organization must engage in. Therefore, the cybersecurity risk management roadmap can be broken into three primary phases: risk management for cybersecurity safeguard selection, risk management for asset prioritization, and risk management for cybersecurity safeguard validation. The assumption is that organizations have already prioritized reducing cybersecurity risks and are now ready to implement a methodology to do so. Each of the other risk management steps falls under one of these purposes.

➤ Risk Management for the Purpose of Safeguard Selection

Safeguard selection is one of the earliest points of intersection with an organization's cybersecurity governance model when managing cybersecurity risks. The process of selecting safeguards is critical to effectively managing cybersecurity risks. By evaluating the potential risks and identifying the necessary safeguards, organizations can better understand what they must do to achieve their goals. Safeguard selection is crucial to ensuring cybersecurity risks are managed effectively and the organization's goals are achieved. Organizations can mitigate potential security threats by identifying and implementing appropriate safeguards to protect their critical assets, infrastructure, and information.

Cybersecurity safeguards most often originate from three sources:

- 1. Legislation and Regulations:** Governments often enact laws and regulations to establish minimum cybersecurity standards. These legal frameworks provide guidelines for protecting sensitive information and maintaining secure networks.
- 2. Contractual Obligations:** When engaging with third-party organizations, businesses often enter into contracts with specific cybersecurity requirements. These agreements ensure that all parties adhere to agreed-upon security protocols to safeguard data exchanges and interactions.
- 3. Industry Standards:** Best cybersecurity practices, established by experts in the field, offer a comprehensive approach to cyber defense. These practices evolve constantly to address emerging threats and are widely adopted across industries to maintain robust security postures.

One should note that the uniqueness of each organization does not necessarily extend to its technology infrastructure. Organizations often employ a widely-used set of technologies, or a 'tech stack,' to achieve their objectives. Given this common use of technology, these organizations would benefit from implementing similar cybersecurity measures. Organizations can ensure a robust defense against potential cyber threats by adopting security protocols that are proven effective for these standard technologies. This approach not only streamlines the process of securing their systems but also leverages collective industry knowledge and experience to fortify their defenses.

> **Risk Management for the Purpose of Asset Prioritization**

Defining the criticality of a technology asset is imperative for an organization to efficiently allocate its resources and prioritize the implementation of cybersecurity safeguards. This aspect of risk management supports asset prioritization, ensuring the most crucial and sensitive assets receive the highest level of protection to maintain organizational integrity, availability, and confidentiality. Through this delineation, organizations can systematically determine which assets are vital to sustaining operational continuity and which, if compromised, could incur significant financial losses or damage the organization's reputation.

The precise ranking of assets by criticality enables a structured approach to safeguard selection, aiding in determining the appropriate security measures required to mitigate potential risks. Furthermore, this prioritization supports safeguard validation by providing a clear framework for evaluating the effectiveness of implemented security measures, ensuring they are commensurate with the criticality and sensitivity of the assets they are designed to protect. Hence, a meticulously crafted asset prioritization strategy is indispensable for a robust cybersecurity risk management program, fostering a well-balanced allocation of security investments in alignment with the organization's risk posture and business objectives.

Organizations often use a Business Impact Analysis (BIA) in coordination with their technology asset inventory to achieve this goal. By analyzing the potential impact of cybersecurity threats to these assets, a BIA can help an organization classify its assets based on how essential they are to business functions. This classification allows organizations to systematically determine which technology systems require immediate protection and which can tolerate lower-tier safeguards or delayed implementation. Using BIA findings, organizations can sequence the deployment of cybersecurity safeguards based on business impact. High-priority systems—those that support core business operations or store highly sensitive data—can be assigned stringent security controls first. Meanwhile, lower-priority systems can be addressed with foundational safeguards as resources allow.

➤ **Risk Management for the Purpose of Safeguard Validation**

Another objective of cybersecurity risk management is to ensure that an organization has established the necessary protective measures to support the achievement of its business objectives. This aspect of risk management, which focuses on validating safeguards, is crucial for confirming that security controls are appropriate and effective at mitigating potential risks. By implementing this risk management approach, organizations can systematically assess and strengthen their security posture, aligning their cybersecurity efforts with their overarching business goals. This proactive approach not only safeguards the organization's assets but also reinforces stakeholders' trust by demonstrating a commitment to robust, effective cybersecurity practices.

This process equips an organization's leadership with a clear, comprehensive understanding of the current state of its cybersecurity measures. By shedding light on potential weaknesses or gaps in the cybersecurity framework, this insight enables leaders to make informed, strategic decisions about allocating resources and setting priorities. Armed with this knowledge, business leaders can direct their efforts and investments more effectively, ensuring that cybersecurity initiatives are aligned with the company's overall objectives and bolster the organization's resilience against digital threats.

Many organizations tend to undervalue the initial stages of cybersecurity risk assessment, choosing instead to fast-track to this latter phase. This approach is prevalent in organizations in the early stages of developing their cybersecurity strategies. While numerous cybersecurity standards require risk assessments, these often focus primarily on comparing an organization against a specific set of cybersecurity safeguards and overlook why those safeguards were selected in the first place. However, it's essential to understand that this phase should represent just one step in a comprehensive journey rather than being the journey's sole focus. This ensures a more robust and resilient cybersecurity framework for the organization.

➤ AN OVERVIEW OF THE GOVERNANCE, RISK, AND COMPLIANCE (GRC) ROADMAP

The Governance, Risk, and Compliance (GRC) Roadmap provides a structured approach to managing cybersecurity within an organization. This roadmap outlines a sequential process for organizations to establish, maintain, and improve their cybersecurity posture. By following this roadmap, organizations can align their cybersecurity efforts with business objectives, regulatory requirements, and industry best practices. The roadmap serves as a blueprint, helping organizations navigate the complexities of cybersecurity governance while ensuring that safeguards are effectively implemented, validated, and communicated.

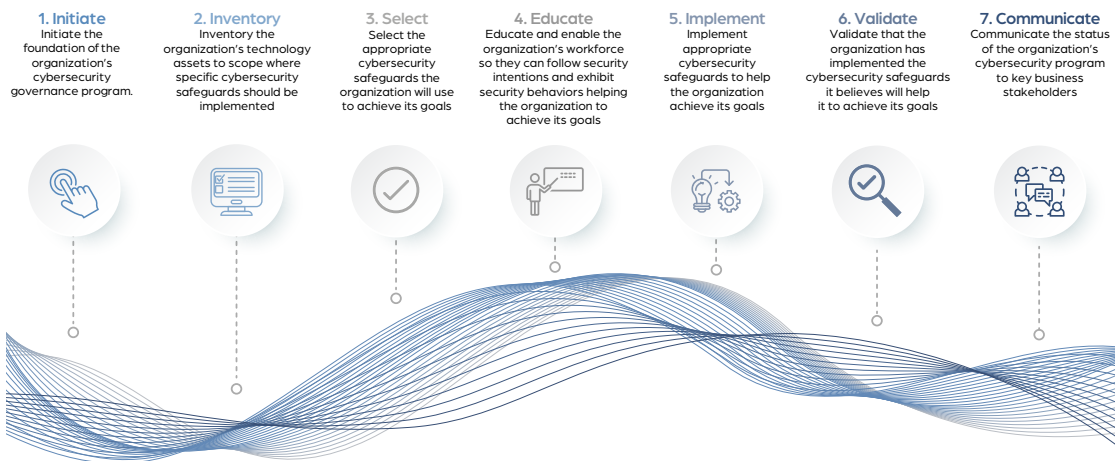
The GRC Roadmap is designed to be a prescriptive, step-by-step framework that removes ambiguity from the cybersecurity governance process. Rather than leaving organizations to interpret abstract guidelines, this roadmap provides a structured sequence of actions that ensures each phase builds logically upon the previous one. By following this methodology, organizations can confidently progress through cybersecurity governance without second-guessing what comes next. This structured approach helps standardize risk management, safeguard selection, validation, and communication, making it easier for organizations of all sizes to implement and maintain an effective cybersecurity program that aligns with business objectives and regulatory requirements.

The seven steps of the GRC Roadmap provide a comprehensive methodology for organizations to manage cybersecurity risks and compliance obligations effectively:

- 1. Initiate:** Establish leadership sponsorship, define cybersecurity governance structures, and set the foundation for a formal cybersecurity program.
- 2. Inventory:** Conduct a thorough assessment of technology assets, data, and business operations to identify key cybersecurity risks and dependencies.
- 3. Select:** Identify and prioritize cybersecurity safeguards based on regulatory requirements, industry best practices, and business risk assessments.

- 4. Educate:** Train employees, executives, and stakeholders on cybersecurity policies, procedures, and awareness initiatives to create a security-conscious culture.
- 5. Implement:** Deploy the selected cybersecurity safeguards and integrate them into daily operations, ensuring alignment with business objectives and risk tolerance.
- 6. Validate:** Assess and audit the effectiveness of implemented safeguards through structured validation processes such as attestation, observation, and continuous monitoring.
- 7. Communicate:** Regularly report cybersecurity risks, program effectiveness, and compliance status to stakeholders to drive informed decision-making and strategic planning.

The diagram below provides a detailed overview of the stages involved in the GRC Roadmap. Each step is essential to building a mature cybersecurity program, and organizations should revisit and refine these steps based on evolving threats, regulatory updates, and operational changes.



➤ STEP ONE: INITIATE

1. Initiate

Initiate the foundation of the organization's cybersecurity governance program.



- A. Obtain senior leadership sponsorship.
- B. Establish a program charter.
- C. Create a program steering committee.
- D. Establish the program's operating structure.

Program initiation within a cybersecurity program involves formally commencing the program's activities. This begins with creating a comprehensive cybersecurity program charter, a foundational document outlining the program's scope, objectives, and key responsibilities. An integral component of program initiation is establishing a cybersecurity steering committee comprising experts from various domains. This committee plays a crucial role in overseeing, guiding, and managing the cybersecurity program. Organizations that set this stage lay the groundwork for a structured, well-coordinated approach to cybersecurity risk management.

A well-structured program charter serves as a guiding document that aligns the cybersecurity program with the organization's strategic objectives and provides clarity to all stakeholders involved in its implementation and management. Specifically, when creating such a charter, organizations will want to add and document the following components when creating the program's charter:

- **Program Purpose:** Clearly state the overarching purpose and objectives of the cybersecurity program.
- **Scope and Boundaries:** Define the program's scope, including the systems, assets, and processes it covers, as well as any exclusions or limitations.
- **Program Oversight Structure:** Describe the governance structure, including the cybersecurity steering committee or other oversight bodies.

- **Stakeholder Identification:** Identify key stakeholders and their roles and responsibilities in the program.
- **Regulatory and Compliance Requirements:** Detail any relevant laws, regulations, or industry standards that the program must comply with.
- **Resource Allocation:** Specify the organization's commitment to budget, personnel, and other resources allocated to the program.
- **Communication Plan:** Explain how information about the program's progress will be communicated to stakeholders, both internally and externally.
- **Review and Audit Processes:** Explain how the program will undergo periodic reviews and audits to ensure it remains effective and aligned with organizational goals.
- **Signatures and Approvals:** Include a section for authorized signatures and approvals, indicating that key stakeholders have reviewed and endorsed the program charter.

In addition, organizations must consider that executive sponsorship is paramount for the success of a cybersecurity program. High-level executives, such as C-level executives or the board of directors, must actively champion and support the program. Their involvement brings several crucial benefits. Firstly, executive sponsorship provides the program with the necessary authority and resources. It signifies the organization's commitment to cybersecurity and ensures the program is adequately funded, staffed, and equipped to meet its objectives. Secondly, it sets the tone for the entire organization by promoting a culture of cybersecurity awareness and accountability. When top leadership demonstrates a strong commitment to cybersecurity, it encourages employees at all levels to prioritize security in their daily activities. Furthermore, executive sponsorship enhances the program's visibility and credibility internally and externally. Stakeholders, including regulatory bodies, business partners, and customers, are more likely to have confidence in the organization's cybersecurity efforts when top leadership actively endorses and supports the program.

➤ STEP TWO: INVENTORY

2. Inventory

Inventory the organization's technology assets to scope where specific cybersecurity safeguards should be implemented.

○ ----- ○

- A. Create a comprehensive technology asset inventory.**
- B. Document business stakeholders for technology assets.**
- C. Perform a Business Impact Analysis (BIA) for all technology assets.**

In the next step in the risk management process, organizations should precisely define the scope of the assets they aim to protect. Ideally, risk management models should adopt a detailed approach, focusing on individual assets. This granular strategy involves posing specific safeguard-related questions at the asset level, leading to a more nuanced and thorough understanding of each asset's unique risks. However, it's essential to recognize the trade-off: dedicating time and resources to regularly update the safeguard status for each asset.

During this phase, the organization should conduct a comprehensive inventory and assessment of its information assets. This classification or characterization process is instrumental in determining the most suitable locations for implementing the previously identified safeguards. Additionally, it helps prioritize which systems require certain safeguards more urgently than others. Such a strategic approach ensures that resources are allocated efficiently and that the most critical assets receive immediate and appropriate levels of protection, aligning with the organization's overall risk management objectives.

Organizations typically will begin by deploying technology tools within their network environment to initiate a logical computing asset inventory. These tools facilitate the identification of different nodes within each network segment. Following this, it's essential to catalog the data sets residing on each asset, a process that is often manual. However, an increasing number of tools are emerging to automate this task, helping identify network shares, databases, and other data repositories on each logical asset. Moreover, organizations should include data managed by third-party business partners or cloud service providers in this inventory.

After completing the data inventory, the next step is to identify data owners (business process owners) and data custodians (technical analysts) for each data set. These individuals should proactively take responsibility for the data assets rather than being arbitrarily assigned. Data sets lacking designated owners should be scrutinized for their relevance to business operations. Once identified, these individuals are responsible for determining the criticality and sensitivity of the data sets under their protection. Technical tools such as host-based data loss prevention and cloud access security brokers are available to assist with this process.

For efficiency, especially in the early stages of program maturity, many organizations may bypass this detailed step and conduct a broader safeguards-oriented assessment for the entire organization. Instead of querying the implementation of safeguards for each asset, they might pose more general, subjective questions about the organization. For instance, instead of asking if a specific server has application safeguards, they might inquire about the percentage of servers with such safeguards. Adopting this broader approach depends on each organization's scope and maturity level. However, as an organization progresses towards a more automated, data-driven approach to risk management, this detailed step becomes increasingly crucial.

➤ STEP THREE: SELECT

3. Select

Select the appropriate cybersecurity safeguards the organization will use to achieve its goals.

○-----○

- A. Define regulatory responsibilities.
- B. Define contractual responsibilities.
- C. Define industry best practices.
- D. Create cybersecurity threat model.
- E. Document board level cybersecurity policy.
- F. Document tactical cybersecurity intentions.

Organizations should establish a systematic process for selecting safeguards early in the cybersecurity governance and risk roadmap. This process involves a multifaceted approach that incorporates threat modeling, prioritization, and mapping specific threats to appropriate safeguards. By undertaking this methodical procedure, organizations proactively identify potential cybersecurity threats, evaluate their potential impact, and prioritize them based on the associated risks. Subsequently, safeguards are selected and implemented strategically to counter these identified threats effectively. This approach ensures that cybersecurity resources are allocated efficiently, addressing the most critical vulnerabilities and safeguarding the organization's digital assets while aligning with its strategic goals.

» Catalog Threats

The initial phase of the risk management roadmap involves creating a detailed inventory of potential threats to an organization's information systems and data. This crucial step aims to develop an exhaustive list of potential threats that could compromise the organization's digital assets. With this information, an organization can devise appropriate defensive measures to prevent, detect, or respond to these threats by identifying each factor that could pose a risk. The thoroughness of this inventory directly influences the organization's ability to formulate a comprehensive strategy that effectively addresses all pertinent risks.

When defining threats, organizations need to recognize that they can be categorized. The primary categories to consider are threat actors (who might initiate the threat), threat actions (what actions they might take), threat targets (what they might target), and threat consequences (what the impact might be). Focusing on these categories helps develop a more structured and holistic view of potential risks.

The core focus of the threat inventory should be the actions threat actors might take to cause harm. These are the specific events that the organization's defensive safeguards aim to prevent, detect, or respond to. While understanding the identity of threat actors might be helpful for entities like law enforcement, this information often doesn't translate into actionable intelligence for most organizations. Instead, the practical approach concentrates on the actions' nature and potential impact. This approach enables organizations to develop targeted strategies more likely to mitigate the identified risks effectively.

» **Threat Modeling**

After developing an inventory of potential threats to its information systems, an organization's next step is to prioritize them, a process known as threat modeling. Prioritization is vital because it enables the organization to focus on implementing the safeguards most relevant to the identified threats. This threat-ranking process is a preparatory stage, laying the groundwork for later steps in which specific defensive measures are chosen and prioritized.

To effectively prioritize threats, an organization must first establish criteria for evaluating each threat's relevance and significance. This involves documenting a comprehensive list of potential threats and determining the parameters for assessing each threat's impact. These criteria typically include factors such as the likelihood of a threat occurring, its potential to cause damage, and the overall impact on the business should the threat materialize. Once these criteria are in place, the organization should develop a consistent scoring or weighting system. This system evaluates each threat against the established criteria, ensuring a uniform approach to threat assessment.

When setting up this scoring system, the organization must document a consistent methodology for rating each criterion for every threat. Each criterion doesn't need to have an identical scoring scale, but the scoring approach for each criterion should be consistent across all threats. For example, the likelihood of occurrence should be evaluated using the same scale for every threat. The organization might use qualitative descriptors for each score, such as 'low,' 'medium,' or 'high,' but these are typically underpinned by a numerical system for easy calculation and comparison. This numerical translation enables the organization to effectively quantify and compare the risks posed by different threats, guiding strategic decision-making in cybersecurity.

» **Catalog Safeguards**

Upon completing the threat modeling process, an organization will have a prioritized list of potential events or actions that could be detrimental. This prioritization is instrumental in helping the organization identify potential barriers to achieving its business objectives. The critical question then becomes: how can the organization effectively counter these threats and prevent their potential impacts?

The next step is for the organization to compile a comprehensive inventory of potential safeguards and defensive measures to address these threats. This inventory should be as exhaustive as possible, encompassing a wide range of protective strategies to ensure that all identified threats are adequately addressed. The goal is to equip the organization with diverse tools and measures to safeguard against various risks.

When building this inventory of safeguards, organizations often turn to established documents and standards that offer guidance on potential defenses. These resources can serve as valuable starting points, especially when tailored to specific industry needs or regulatory requirements. For example, the selection of safeguards for a small retail business will differ significantly from those suitable for a large international defense contractor. Each organization should consider the laws, regulations, and industry standards most relevant to its specific sector and operational context. Doing so, they can develop a tailored and effective safeguard library that aligns with their unique risk profile and business needs.

» Map Threats to Safeguards

After compiling and prioritizing the potential threats to the organization and identifying corresponding defenses, the next crucial phase in the risk management cycle involves aligning the threats identified in the threat model with the safeguards listed in the safeguard library. This step, known as mapping, entails identifying which specific threats each safeguard can address. Through this process, an organization understands the actionable steps required to mitigate each threat in the inventory.

Since every threat is ranked in the threat model, mapping these threats to specific safeguards yields a prioritized list of safeguards. The most effective approach usually starts with the threat inventory as the primary reference point and assigns appropriate safeguards to each listed threat. During this exercise, it's common to find that some safeguards apply to multiple threats, while others in the safeguard library might not be used. This outcome is typical and expected at this stage of the risk management cycle.

One of the more complex aspects of this phase is assessing the extent of coverage each safeguard provides concerning each threat. Often, organizations will discover that a combination of safeguards is required to fully mitigate a particular threat, a concept central to the defense-in-depth approach in information security. For instance, while application safeguard restrictions might be crucial for protecting computer workstations from malicious software, they will likely need to be supplemented with other safeguards to fully address the risk. Determining the effectiveness and comprehensiveness of any safeguard against a specific threat involves a blend of analytical judgment and experience. Organizations should generally anticipate the need for multiple safeguards to adequately address each identified threat.

» **Safeguard Prioritization**

Upon reaching this stage in the risk management roadmap, an organization should have a clearly defined set of prioritized cybersecurity measures customized to its unique needs and risk profile. This milestone signifies the completion of the initial phase of the risk management roadmap. These prioritized safeguards are vital for addressing the most pressing threats and vulnerabilities, ensuring that the organization allocates its resources and efforts towards areas of greatest concern. Establishing this foundation is crucial as it sets the stage for subsequent phases in the roadmap, empowering the organization to effectively mitigate risks, safeguard its assets, and fulfill its cybersecurity goals.

» **Safeguard Documentation**

In the final step of this phase, an organization must document the selected cybersecurity safeguards meticulously. This process involves crafting structured documents that detail the descriptions, objectives, implementation strategies, responsible entities, timelines, and review mechanisms for each safeguard. Such documentation is crucial for effective management, continuous monitoring, and the enhancement of cybersecurity measures, ensuring they align with the organization's broader goals and objectives.

The primary aim of this documentation phase is to precisely record the safeguards that organizational leaders deem appropriate for achieving the organization's mission. While organizations may refer to these documents by various names - such as policies, procedures, standards, or guidelines - the essential element here is not the title of the documents but the clarity with which the organization's intentions and strategies are articulated. This clarity is critical to ensuring the safeguards are implemented efficiently and consistently across the organization.

Defining and documenting an organization's cybersecurity safeguards culminates in establishing clear cybersecurity goals. These goals act as a foundational framework for the organization, outlining a comprehensive strategy for implementing cybersecurity measures. With these documented objectives, every organization member gains a unified understanding of the cybersecurity targets to strive towards. This shared vision fosters a coordinated approach to protecting critical assets and information. Furthermore, such well-defined goals significantly strengthen the organization's security stance and foster a culture of cybersecurity awareness and responsibility.

> STEP FOUR: EDUCATE

4. Educate

Educate and enable the organization's workforce so they can follow security intentions and exhibit secure behaviors helping the organization to achieve its goals.



- A. Educate workforce on cybersecurity awareness.**
- B. Enable workforce to exhibit cybersecurity intentions and behavior.**
- C. Educate and enable workforce on responsibilities by role.**

Following the definition of cybersecurity safeguards, the organization proceeds to educate its workforce on their specific roles and responsibilities in maintaining a secure digital environment. This educational phase entails providing employees with comprehensive knowledge and awareness of how to effectively protect sensitive information and systems. It covers a range of topics, including clear guidelines for safe online practices, protocols for reporting security incidents, and the organization's cybersecurity policies and procedures. Ensuring that each employee understands their unique responsibilities in safeguarding digital assets reduces the risk of inadvertent actions that could compromise security. Furthermore, this educational effort bolsters the organization's overall security measures and instills a culture of heightened awareness and individual accountability.

While a portion of the education raises general awareness of cybersecurity issues, such as safe email practices, the primary objective of this step is to ensure that the organization's workforce has a comprehensive understanding of its specific policies and procedures. This focused education ensures that employees recognize the broader cybersecurity landscape and grasp the intricacies of the organization's internal security measures. By clarifying these policies, the organization equips its workforce to operate within established guidelines, reducing the likelihood of inadvertent breaches and ensuring consistent adherence to the organization's security protocols. This step is pivotal in harmonizing employee actions with organizational security objectives, reinforcing a culture of compliance, and collectively safeguarding critical digital assets.

> STEP FIVE: IMPLEMENT

5. Implement

Implement appropriate cybersecurity safeguards to help the organization achieve its goals.



- A. Implement approved, tactical cybersecurity intentions.**
- B. Document exceptions to approved, tactical cybersecurity intentions.**
- C. Document issues identified with approved, tactical cybersecurity intentions.**

After educating its workforce and performing a comprehensive inventory of its technology assets, an organization should move forward with actively implementing its cybersecurity policies. This phase involves taking definitive actions to implement the outlined safeguards. The implementation encompasses a range of tasks, including installing security tools and systems, modifying existing procedures as needed, and routinely evaluating the efficacy of these security measures.

The core objective is to transform policy directives into tangible actions that bolster the organization's security posture. By methodically executing these safeguards, the organization enhances its defenses against cyber threats. This process ensures that operational activities align with established security policies, resulting in a fortified, resilient digital environment. This proactive approach safeguards the organization's digital assets and reinforces its commitment to comprehensive cybersecurity.

>> Project Management

Once an organization decides on a set of prioritized safeguards for defense, the next crucial step is to implement these measures. This stage focuses on implementing strategies to ensure the organization's information systems achieve their intended objectives. Most organizations face limited resources, which constrain their ability to implement every possible safeguard. Adopting a project management approach aligned with the established priorities is a wise strategy in this context.

Setting realistic goals and timelines is essential for the success of any program an organization undertakes. While agreeing on actions may seem straightforward, executing them can be challenging due to competing priorities and differing views on the importance of specific safeguards. Moreover, leadership may need to grapple with temporarily accepting some level of risk as they work on addressing security issues in the long term.

Adherence to fundamental project management principles is critical to successfully implementing the security safeguard library. Following industry standards, such as those set by the Project Management Institute, ensures that each safeguard is implemented efficiently and aligns with the organization's objectives.

Organizations might consider deploying technical tracking tools to better manage the implementation process. Those new to project management might start with essential spreadsheet-based tools, while more resource-endowed organizations could opt for a Governance, Risk, and Compliance (GRC) system. Such systems help track the priorities and progress of safeguard implementation and facilitate subsequent validation and reporting stages.

» **Exception Management**

Establishing an exception process is crucial to implementing an organization's safeguards. This process allows the organization to define specific circumstances or conditions under which policy exceptions can be considered and granted. Policies are often written aspirationally, outlining what should be done ideally, even if the organization may not always be able to comply immediately. The exception process provides a structured framework for evaluating and approving deviations from these policies when necessary. It ensures that exceptions are granted for valid, documented reasons, balancing security objectives and operational necessities.

Organizations may sometimes need to issue blanket policy exceptions that apply to all their assets. These exceptions typically arise when specific policies, due to their nature or inherent constraints, cannot be uniformly applied to all assets without causing operational disruptions or undue burden. When implementing blanket exceptions, careful consideration should be given to their scope, duration, and compensatory measures to maintain security. Such exceptions must be clearly defined, documented, and periodically reviewed to ensure they align with the organization's evolving security needs while minimizing potential risks associated with deviations from established policies.

In addition to blanket exceptions, there are instances where policy exceptions may be required on a system-by-system or asset basis. Business owners of specific assets or systems may encounter unique circumstances or operational needs that necessitate deviations from standard policies. These exceptions can be sought through a formal request process that requires providing a compelling justification for the deviation, outlining the specific safeguards or compensatory measures to mitigate associated risks, and obtaining the appropriate approvals from relevant stakeholders, including the organization's security and compliance teams. This system-specific exception process ensures flexibility where necessary while maintaining a structured framework for evaluating and managing exceptions to safeguard the organization's overall security posture.

» **Issue Management**

Continuing the topic of safeguard implementation, a critical aspect organizations must consider is issue management, particularly through the implementation of an issue-tracking system. This system is vital for identifying specific instances where the organization falls short in actualizing its documented cybersecurity strategies.

Issue tracking is a mechanism for pinpointing and recording discrepancies between the organization's cybersecurity plans and their execution. When an organization documents its cybersecurity intentions, these plans serve as the blueprint for securing its information systems. However, it's common to encounter situations where these intentions are not fully realized due to various constraints or oversights.

A practical issue-tracking system helps identify, document, and systematically address these gaps. Organizations can use various tools for issue tracking, ranging from simple databases or spreadsheets to more sophisticated software systems integrated with their project management or GRC tools. The key is to choose a system that fits the organization's size, complexity, and specific needs. Issue management will allow an organization to identify specific situations in which its stated safeguard objectives are not being met, potentially introducing cybersecurity risk.

» **An Aside: Risk Registers and Risk Tracking**

A formal cybersecurity risk register is the definitive source of truth for all approved cybersecurity exceptions within the organization. It is a centralized repository where each exception is meticulously documented, including its rationale, scope, and duration. Maintaining a comprehensive record of exceptions in this register ensures transparency, accountability, and traceability in its cybersecurity governance. This centralized approach facilitates efficient exception tracking and supports risk management, enabling the organization to continuously monitor, assess, and address the impact of exceptions on its overall security posture. As the primary reference point for cybersecurity exceptions, the risk register is pivotal in maintaining the delicate balance between operational flexibility and security integrity.

These exceptions should only be approved by the organization's cybersecurity steering committee. This committee comprises cybersecurity experts and stakeholders with a holistic view of the organization's security landscape. Their involvement ensures that exceptions are evaluated comprehensively, taking into account the organization's strategic objectives, risk tolerance, and compliance requirements. The committee's oversight ensures that exceptions are not granted haphazardly but are aligned with the organization's broader cybersecurity goals. This rigorous approval process reinforces the organization's commitment to maintaining a robust security posture while allowing for necessary operational flexibility. Moreover, it fosters consistency, accountability, and transparency in exception handling, safeguarding the organization against potential security vulnerabilities arising from deviations from established policies.

Documenting exceptions in a risk register can be achieved using various tools, depending on the organization's needs and complexity. For more straightforward approaches, organizations may use readily available tools like Microsoft Excel to maintain a spreadsheet-based risk register. This approach offers simplicity and flexibility for smaller organizations or those with limited resources. Conversely, more comprehensive governance, risk, and compliance (GRC) platforms offer a robust, centralized solution for documenting exceptions. GRC platforms offer advanced features such as automated workflows, audit trails, and integration with other security and compliance management tools, making them ideal for larger and more complex organizations. Regardless of the tool chosen, the key is to ensure that exceptions are documented systematically and comprehensively, in a manner that supports efficient tracking, reporting, and analysis to manage cybersecurity risks effectively.

➤ STEP SIX: VALIDATE

6. Validate

Validate that the organization has implemented the cybersecurity safeguards it believes will help it to achieve its goals.



- A. Validate safeguards via attestation and observation.**
- B. Validate safeguards via penetration testing.**
- C. Validate safeguards via continuous monitoring.**

The purpose of the Validate step in the Governance, Risk, and Compliance (GRC) Roadmap is to ensure that the organization has established formal, governed processes for confirming that approved cybersecurity safeguards are implemented as intended. Validation at this stage is not about performing technical testing directly; it is about governing validation, selecting appropriate validation mechanisms, and ensuring that results are reviewed and acted upon through leadership oversight.

Validation activities may be executed through multiple mechanisms, including independent audits, structured assessments, and the review of supporting evidence. Within the CRF ecosystem:

- **The CRF Audit Framework (CRF-AF) defines how independent validation and assurance are performed, including roles, evidence standards, and governance requirements.**
- **The CRF Business Intelligence Model (CRF-BIM) defines how continuous evidence and metrics are generated to support validation and oversight.**
- **The CRF-GRM coordinates when and why validation activities occur and how results are governed.**

Organizations should establish a validation strategy that determines:

- **Which safeguards require independent audit assurance,**
- **Which safeguards are supported by continuous evidence and monitoring,**
- **The appropriate frequency and scope of validation activities, and**
- **The governance forums are responsible for reviewing validation results.**

This strategy ensures that validation efforts are risk-informed, repeatable, and aligned with organizational priorities rather than reactive or ad hoc.

» **Validation Mechanisms**

Validation may leverage a combination of mechanisms, each providing different levels of confidence and assurance. These mechanisms commonly include attestations, direct observations, continuous evidence generated by technical systems, and effectiveness testing such as penetration testing. Each mechanism has different cost, coverage, and assurance characteristics and should be selected deliberately based on risk, criticality, and governance needs.

The CRF Audit Framework defines how these mechanisms are applied within independent audits and assessments. The CRF Business Intelligence Model defines how automated and continuous evidence is collected and structured to support validation. The GRM does not prescribe how these mechanisms are executed; it ensures that their use is intentional, governed, and aligned with organizational objectives.

Validation results provide leadership with visibility into gaps between documented cybersecurity intentions and actual implementation. These results inform risk management decisions, resource allocation, and prioritization, but they do not automatically prescribe remediation actions. Management remains responsible for determining how identified gaps are addressed, while governance bodies ensure that decisions are deliberate, documented, and aligned with risk appetite.

The maturity of how validation is orchestrated across audits, assessments, and evidence sources is measured using the CRF Governance & Risk Management Maturity Model (CRF-GRMM). As organizations mature, validation becomes more structured, better integrated with governance workflows, and supported by higher-quality evidence—without changing the independent nature of audit assurance.

➤ STEP SEVEN: COMMUNICATE

7. Communicate

Communicate the status of the organization's cybersecurity program to key business stakeholders.



- A. Communicate risk to leadership stakeholders.**
- B. Communicate risk to business stakeholders.**
- C. Communicate risk to technical stakeholders.**
- D. Communicate risk to business partners.**

The subsequent phase in the risk management roadmap involves educating relevant business stakeholders about the risks their information systems face, a process commonly referred to as risk reporting. This phase culminates all the preceding steps in the risk management process. The primary objective of any metrics or measurement program is to facilitate informed decision-making within an organization. Therefore, after an organization completes the earlier stages, including safeguard validation, it should communicate the findings to the pertinent stakeholders. This ensures they are well-informed about the risks their systems are exposed to and can make more informed decisions about addressing them.

Risk reporting is typically conducted using previously mentioned tools, such as spreadsheets or Governance, Risk, and Compliance (GRC) software, and the results should be presented to all relevant stakeholders. These stakeholders range from business owners who rely on a particular information system to senior executives at the board level. Essentially, anyone realizing a risk might impact should have the opportunity to participate in this process. This inclusive approach to risk reporting ensures that all relevant parties know the risks and are involved in the decision-making process to address them effectively.

➤ **PROGRESSING TOWARDS CYBERSECURITY PROGRAM MATURITY**

As an organization progresses through each phase of the cybersecurity risk management cycle, it significantly enhances its capability to meet its cybersecurity objectives. Developing a mature cybersecurity program equips the organization with the tools to protect its technological infrastructure, safeguard sensitive data, and effectively respond to security challenges. Successfully navigating these stages directly contributes to achieving the organization's cybersecurity goals, including the integrity, availability, and confidentiality of its digital resources.

The primary aim of a cybersecurity program is to ensure the uninterrupted and secure functioning of an organization's information systems. These systems' secure and reliable operation is fundamental to the organization's ability to pursue its mission effectively. A robust cybersecurity program protects critical data, prevents cyber threats, and ensures continuous system availability. This security framework serves as a facilitator, enabling the organization to focus on its core business objectives, whether they involve service delivery, innovation, or other strategic endeavors.

A well-established cybersecurity program is critical to ensuring that technology is a valuable asset, bolstering the organization's success rather than becoming a liability. This comprehensive approach to cybersecurity preserves the organization's operational integrity and lays the groundwork for achieving its broader mission and strategic goals.

➤ CONCLUSION

In conclusion, we have outlined the critical components and phases of cybersecurity risk management, emphasizing the importance of a structured, strategic approach within organizations. From the initial stages of identifying and cataloging threats to implementing and validating safeguards, each step in the risk management roadmap plays a vital role in fortifying an organization's defense against evolving cyber threats. The process, grounded in a deep understanding of potential risks and the most effective countermeasures, underscores the need for a proactive, well-informed cybersecurity posture.

The research has also highlighted the significance of continuous improvement and adaptation in cybersecurity strategies. As digital threats become increasingly sophisticated, it is imperative for organizations to not only establish robust cybersecurity measures but also continually assess and refine them. This dynamic approach ensures that cybersecurity efforts align with evolving technological landscapes and organizational goals, thereby maintaining the integrity, availability, and confidentiality of critical digital resources.

However, navigating the complexities of cybersecurity is not a journey organizations should undertake in isolation. Collaboration and knowledge-sharing within the broader community are essential. Organizations can develop more comprehensive and effective cybersecurity strategies by working together, sharing experiences, and learning from each other. Collective efforts in research and development, sharing best practices, and engaging in open dialogues about emerging threats and innovative defenses can significantly enhance the cybersecurity posture of individual organizations and the business community.

Therefore, this research serves as a guide for individual organizations and a call to action for the broader cybersecurity community. It encourages organizations to contribute to and participate in ongoing cybersecurity research and discussions. By fostering a culture of collaboration and continuous learning, businesses can collectively strengthen their defenses against cyber threats, ensuring a safer digital environment for all.

➤ ABOUT THE CYBERSECURITY RISK FOUNDATION (CRF)

The Cybersecurity Risk Foundation's (CRF) purpose is to encourage global collaboration and knowledge-sharing among cybersecurity professionals. Established with the mission to address the practical challenges that organizations face in cybersecurity, the CRF embodies a collective endeavor to fortify digital landscapes against ever-evolving threats. Our foundation is built on the principle that unity in action and thought can significantly enhance cybersecurity, promoting safer, more resilient digital environments for businesses and institutions across sectors.

At the heart of the CRF is a vibrant community of experts, practitioners, and thought leaders who bring a wealth of experience and insights from diverse cybersecurity fields. This rich tapestry of knowledge serves as the foundation for our collaborative efforts to develop, refine, and disseminate practical strategies and solutions to common cybersecurity challenges. Through workshops, whitepapers, forums, and collaborative research initiatives, the CRF facilitates the exchange of ideas and best practices, encouraging innovation and continuous learning among its members. We aim to create a dynamic repository of cybersecurity knowledge that addresses current threats and anticipates future challenges, equipping organizations with the tools and strategies they need to navigate the digital age securely.

We invite cybersecurity professionals and organizations to join our mission, contribute to our body of knowledge, and engage in collaborative initiatives. Whether through sharing experiences, participating in discussions, or contributing to our ongoing research efforts, your involvement can make a significant difference. Together, we can create a powerful force for change, advancing cybersecurity practices and fostering a culture of security that transcends organizational boundaries. The CRF is more than just a foundation; it is a community of shared purpose committed to making the digital world a safer place for everyone.



crfsecure.org